

Human–AI Interaction — Séance 4

AI Act & RGPD

(+ Démarrage “Hello logs”)

François Bouchet - LIP6 / Sorbonne Université

Cours HAI | Master AI2D

20 octobre 2025

Introduction

Pourquoi cette séance ?

- En S1 : **pas de HCAI solide sans HAI mesuré**
- En S4 : **pas de HAI crédible sans gouvernance démontrable**
- RGPD et AI Act = même exigence : produire des **preuves de maîtrise**
- Nous allons voir : *quelles preuves, pour qui, et comment les concevoir dès le design*

Sondage Wooclap (5 min)

« Les cadres européens freinent-ils l'innovation en IA ? »

Panorama européen

Du RGPD à l'AI Act : une continuité de gouvernance

- 2018 : **RGPD** — protéger les personnes
- 2024 : **AI Act adopté** — encadrer les systèmes IA selon le risque
- 2024 : création de l'**EU AI Office** (supervision européenne)
- 2025+ : **Data Act** et **ePrivacy Regulation** compléteront l'ensemble

Une trajectoire de continuité européenne

- **RGPD (2018)** : protéger les personnes & leurs données
- **AI Act (2024)** : encadrer les *systèmes* d'IA selon le risque
- **Logique commune** : traçabilité, transparence, *accountability* : preuves d'usage et de supervision

Message clé pour HAI

Du “mesurer l'équipe H+IA” (S1) à “**prouver** la maîtrise du système” (S4)

Cadres connexes à venir :

- **Data Act (2025)** : partage équitable et accès sécurisé aux données industrielles ; crée un droit de portabilité étendu.
- **ePrivacy Regulation (2026 ?)** : complète le RGPD pour les communications électroniques (cookies, messageries, métadonnées).

Sources : Commission européenne AI Act overview (2024) ; EPRS Briefing Implementation Timeline (2025)

L'Europe n'est pas seule : panorama rapide

Région	Approche	Particularités / Points saillants
 États-Unis	Régulation fragmentée	FTC : lutte contre pratiques déloyales ; NIST AI RMF (2023) : cadre volontaire de gestion des risques ; pas de loi fédérale globale sur l'IA
Californie	Cadre " <i>Frontier AI</i> " (SB 53, 2025 pour 01/2026)	Obligation de transparence, d'évaluation de sécurité et d'audit pour modèles puissants ; sanctions locales
 Chine	Ensemble de règlements successifs (2021-2023)	Règles sur recommandations algorithmiques (2021) ; deepfake / synthèse (2022) ; IA générative (2023) → cadre quasi global fondé sur transparence, responsabilité et contrôle des contenus par Cyberspace Administration of China

Sources : Federal Trade Commission (FTC) Guidance on AI ; NIST AI Risk Management Framework (2023) ; Californie SB 53 (2025) ; China Generative AI Rules (2023)

Pourquoi parler de « continuité » RGPD → AI Act ?

RGPD (*personnes*)

- Licéité, transparence, minimisation
- Droits (accès, effacement, portabilité)
- Pseudonymisation, rétention
- Responsabilité du *responsable de traitement*

AI Act (*systèmes*)

- Gestion du risque, *human oversight*
- Transparence d'usage (info utilisateur)
- **Logs** & documentation technique
- Suivi post-marché & évaluation de conformité

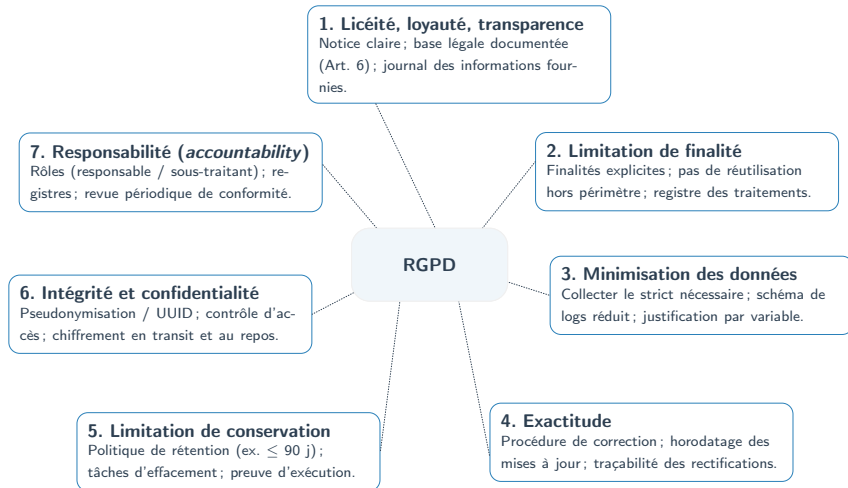
Pont HAI ↔ HCAI

Même exigence de “preuves” : *override/fallback* logués, explications utiles, traces d'usage, politiques de rétention.

RGPD : principes et impacts

Les 7 principes fondamentaux du RGPD

RGPD : 7 principes = 7 preuves à produire



Ce qu'est (et n'est pas) une donnée personnelle

Définition (Art. 4.1 RGPD)

Donnée personnelle : toute information se rapportant à une **personne physique identifiée ou identifiable**, directement ou indirectement.

Exemples évidents : nom, adresse, numéro de sécurité sociale, photo de visage

Exemples moins triviaux :

- identifiant technique (adresse IP, identifiant cookie, UUID si lien persistant)
- enregistrement audio où la voix peut être reconnue
- données de localisation fine ou combinaison de signaux (âge + ville + profession)

Ce qu'est (et n'est pas) une donnée personnelle

Définition (Art. 4.1 RGPD)

Donnée personnelle : toute information se rapportant à une **personne physique identifiée ou identifiable**, directement ou indirectement.

Exemples évidents : nom, adresse, numéro de sécurité sociale, photo de visage

Exemples moins triviaux :

- identifiant technique (adresse IP, identifiant cookie, UUID si lien persistant)
- enregistrement audio où la voix peut être reconnue
- données de localisation fine ou combinaison de signaux (âge + ville + profession)

Et un "traitement de données" ?

Toute opération réalisée sur ces données : *collecte, enregistrement, organisation, conservation, consultation, transmission, effacement...*

⇒ même un simple **tableur de suivi ou un log expérimental** constitue un traitement !

Source : Règlement (UE) 2016/679, Art. 4.1–2 ; CNIL – Définition "donnée personnelle".

Les bases légales de traitement (Art. 6)

- Consentement explicite
- Contrat (nécessaire pour CGU) ou obligation légale (e.g. facturation)
- Mission d'intérêt public (e.g. universités pour missions précises, bases statistiques)
- Intérêt légitime du responsable (e.g. prévention fraude)
- Sauvegarde des intérêts vitaux (cas extrêmes)
- **Recherche scientifique**¹ (**Art. 89**) : dérogation possible MAIS partielle et avec garanties techniques/organisationnelles appropriées. Plan de gestion de données à prévoir².

1. Q&R de la CNIL sur recherche scientifique

2. Outil Data Management Plan

- Accès, rectification, effacement, portabilité, opposition
- Notification en cas de violation
- Responsabilité partagée : responsable de traitement / sous-traitant

Cas Cambridge Analytica (2014-2018)

Collecte sans consentement clair (test de personnalité “académique”) → absence de minimisation (collecte des données amis – faille Facebook) et finalité explicite (publicité ciblée).

Source : https://fr.wikipedia.org/wiki/Scandale_Facebook-Cambridge_Analytica

Anonymisation, chiffrement, pseudonymisation : définitions & limites

- **Anonymisation (IRRÉVERSIBLE)** : transformation telle que la personne n'est plus identifiée « de façon raisonnable » par quelque moyen que ce soit.
→ si c'est le cas, **ce ne sont plus des données personnelles** (RGPD non applicable).
- **Chiffrement (RÉVERSIBLE si clé existante)** : pas de clé = pas d'accès, mais la donnée reste potentiellement « personnelle » tant que la clé existe ou peut être retrouvée.
- **Pseudonymisation** : remplacement d'identifiants directs (nom, mail) par un identifiant (ex. UUID) ; réduit le lien direct mais **reste des données personnelles** si un tiers détient (ou peut reconstituer) la table de correspondance.

Message clé

Pseudonymisation = bonne pratique de sécurité, *mais* n'équivaut pas à anonymisation. Seule l'anonymisation irréversible sort du périmètre RGPD.

Même un log “sans nom” peut permettre l'identification via recoupements (localisation, âge, horodatage. .).

Réfs utiles : RGPD (Art. 4), EDPB « Guidelines on anonymisation & pseudonymisation » (EDPB 2020), CNIL — pages Pseudonymisation / Anonymisation.

Exercice (5-10 min) : supprimer le nom ne suffit pas

Consigne (binômes) :

- 1 Regardez la table fictive ci-dessous (6 lignes) — *les données sont factices*
- 2 Supprimez mentalement la colonne nom (ou cachez-la)
- 3 Discutez : y a-t-il des lignes qui deviennent uniques (risque de ré-identification) ? Quelles colonnes créent l'unicité ?
- 4 Proposez 2 actions pour atténuer le risque

nom	CP	âge	maladie	date_visite
A. Dupont	75001	45	diabète	2025-09-10
B. Martin	75008	32	asthme	2025-09-11
C. Durand	75001	45	diabète	2025-09-10
D. Lopez	75012	72	cancer	2025-09-09
E. Moreau	75001	29	grippe	2025-09-11
F. Petit	75020	32	asthme	2025-09-11

Exercice (5-10 min) : supprimer le nom ne suffit pas

Consigne (binômes) :

- 1 Regardez la table fictive ci-dessous (6 lignes) — *les données sont factices*
- 2 Supprimez mentalement la colonne nom (ou cachez-la)
- 3 Discutez : y a-t-il des lignes qui deviennent uniques (risque de ré-identification) ? Quelles colonnes créent l'unicité ?
- 4 Proposez 2 actions pour atténuer le risque

nom	CP	âge	maladie	date_visite
A. Dupont	75001	45	diabète	2025-09-10
B. Martin	75008	32	asthme	2025-09-11
C. Durand	75001	45	diabète	2025-09-10
D. Lopez	75012	72	cancer	2025-09-09
E. Moreau	75001	29	grippe	2025-09-11
F. Petit	75020	32	asthme	2025-09-11

k-anonymité sur la table d'exemple

Quasi-identifiants (QI) utilisés : CP, âge, maladie, date_visite.

Rappel : k-anonymité = chaque combinaison de QI apparaît au moins k fois.

1) Avant généralisation : QI exacts

- (75001, 45, diabète, 2025-09-10) $\rightarrow k=2$ (A. Dupont, C. Durand)
- (75008, 32, asthme, 2025-09-11) $\rightarrow k=1$ (B. Martin)
- (75012, 72, cancer, 2025-09-09) $\rightarrow k=1$ (D. Lopez)
- (75001, 29, grippe, 2025-09-11) $\rightarrow k=1$ (E. Moreau)
- (75020, 32, asthme, 2025-09-11) $\rightarrow k=1$ (F. Petit)

$\rightarrow$ Problème : plusieurs classes avec $k=1$ (ré-identification plausible).

k-anonymité sur la table d'exemple

Quasi-identifiants (QI) utilisés : CP, âge, maladie, date_visite.

Rappel : k-anonymité = chaque combinaison de QI apparaît au moins k fois.

2) Après généralisation légère : QI renforcés

- CP $\rightarrow$ ville = *Paris* (au lieu de 75001/08/12/20)
- âge $\rightarrow$ tranches : 20–29 ; 30–39 ; 40–49 ; 70–79
- date_visite $\rightarrow$ semaine = *sept. semaine* (même semaine pour l'exemple)

Nouvelles classes (QI généralisés) :

- (Paris, 40–49, diabète, semaine sept.) $\rightarrow$ k=2 (A, C)
- (Paris, 30–39, asthme, semaine sept.) $\rightarrow$ k=2 (B, F)
- (Paris, 70–79, cancer, semaine sept.) $\rightarrow$ k=1 (D)
- (Paris, 20–29, grippe, semaine sept.) $\rightarrow$ k=1 (E)

$\rightarrow$ *Mieux, mais encore insuffisant (k=1 persiste).*

k-anonymité sur la table d'exemple

Quasi-identifiants (QI) utilisés : CP, âge, maladie, date_visite.

Rappel : k-anonymité = chaque combinaison de QI apparaît au moins k fois.

3) Objectif et atténuations (viser $k \geq 3$)

- **Généraliser plus** : âge en classes plus larges (20–39 ; 40–79), date en *mois* (septembre)
- **Réduction de dimension** : retirer maladie *ou* regrouper en catégories (respiratoire / métabolique / oncologique / infectieux)
- **Suppression ciblée** (sampling) : retirer ou agréger les lignes rares jusqu'à $k \geq 3$
- S'assurer que les **valeurs sensibles** soient **variées** dans un groupe de QI (l-diversity)
- S'assurer que chaque groupe k-anonyme ait des **proportions similaires** au jeu de données complet (t-closeness)

Obligations des systèmes à haut risque (1/2)

Articles 9 à 12 : chaîne qualité et traçabilité

Article	Contenu AI Act (2024)	Parallèle HAI / RGPD
9	Risk management : cycle continu identification, évaluation, atténuation des risques	Principe de <i>responsabilité</i> du RGPD (accountability) : obligation de preuve
10	Data & data governance : qualité, représentativité, absence de biais, traçabilité des données d'entraînement	Principe de <i>minimisation</i> et de <i>loyauté</i> ; équité des slices ; documentation des sources
11	Technical documentation : description du système + performances + limites + contexte d'usage	Notice d'information RGPD ; traitement transparent ; logs + README technique.
12	Record-keeping : journalisation automatique fonctionnement et événements.	Traçabilité RGPD ; base de preuve pour DPIA ; équivalent "preuve de conformité"

Message clé

Une **logique qualité-traçabilité** : définir le risque, documenter le modèle, suivre son exécution.
C'est la continuité du "privacy by design" → "governance by design".

Obligations des systèmes à haut risque (2/2)

Articles 13 à 15 et 61 : supervision, robustesse et suivi

Article	Contenu AI Act (2024)	Parallèle HAI / RGPD
13	Transparency and information : informer l'utilisateur du rôle / limites de l'IA	Devoir d'information RGPD ; UI explicites (microcopies, badges, incertitude)
14	Human oversight : garantir une intervention ou un arrêt humain possible	Logique HAI (G8-G10) : <i>dismiss, override, fallback</i> ; supervision humaine = garde-fou
15	Accuracy, robustness, cybersecurity : exigences de fiabilité et de sécurité	Principe d' <i>intégrité/confidentialité</i> RGPD ; équivalent technique des garde-fous
61	Post-market monitoring : suivi continu et rapport des incidents	Mise à jour continue du protocole HAI ; équivalent d'une <i>AIPD vivante</i>

Message clé

Ces articles complètent la boucle par la **supervision humaine** et la **maintenance responsable**.
RGPD protège les personnes ; AI Act fiabilise le système.

Qui fait quoi ? Les rôles dans l'écosystème AI Act

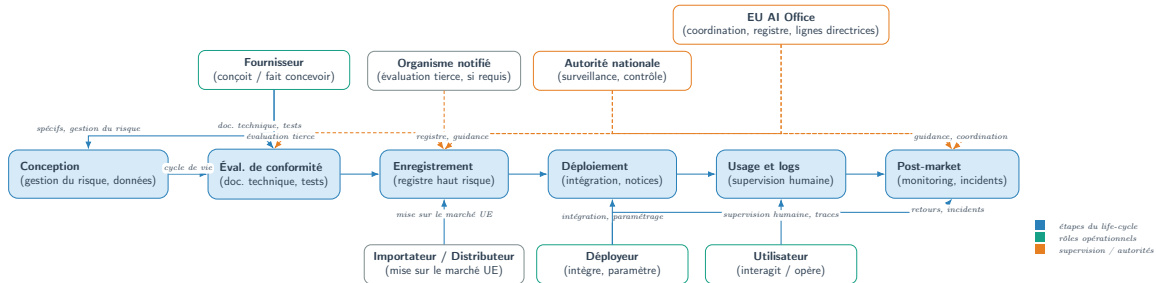
- **Fournisseur** : conçoit ou fait concevoir le système d'IA ; responsable de la conformité technique (arts. 9–15)
- **Déploieur** : intègre le système dans un environnement réel ; veille à son bon usage et à la supervision humaine
- **Utilisateur** : interagit avec le système (humain ou organisation).
- **Autorité compétente / AI Office** : supervision européenne et registre public des IA à haut risque (≈ 120 personnes en 2025, profils techniques, juridiques, économistes. . .)

Pont RGPD ↔ AI Act

Les obligations ne concernent pas que la technique : elles s'étendent à la **documentation et au suivi du risque**.

Qui fait quoi ? Les rôles dans l'écosystème AI Act

AI Act — Rôles et cycle de vie



Comparatif RGPD ↔ AI Act

Dimension	RGPD	AI Act
Sujet	Données personnelles	Systèmes d'IA
Finalité	Protection des personnes	Sécurité / fiabilité du système
Acteur clé	Responsable traitement	Fournisseur / Déployeur
Preuve attendue	Consentement, minimisation	Logs, AIPD, guardrails
Rétroaction	Droits des personnes	Monitoring post-marché

AIPD / DPIA

L'AIPD (ou DPIA) : le pont entre RGPD et AI Act

Origine RGPD (Art. 35)

Analyse d'impact sur la protection des données : obligatoire quand un traitement présente un **risque élevé pour les droits et libertés** (profilage, surveillance, IA sensible. . .).

Pourquoi elle s'applique aussi à l'AI Act :

- L'AI Act reprend la même logique de **gestion de risque documentée**
- Les autorités (EDPB + AI Office) encouragent l'**intégration de l'AIPD dans le dossier technique AI Act**
- Pour la recherche ou les prototypes : l'AIPD démontre déjà la conformité RGPD et fournit la structure de "risk management" exigée par l'AI Act

Logiciels d'aide : <https://www.cnil.fr/fr/outil-pia-telechargez-et-installez-le-logiciel-de-la-cnil>

L'AIPD (ou DPIA) : le pont entre RGPD et AI Act

Origine RGPD (Art. 35)

Analyse d'impact sur la protection des données : obligatoire quand un traitement présente un **risque élevé pour les droits et libertés** (profilage, surveillance, IA sensible. . .).

Contenu minimal recommandé

- ① Description du traitement / du système IA
- ② Évaluation de la nécessité et de la proportionnalité
- ③ Analyse des risques pour les droits et libertés
- ④ Mesures techniques et organisationnelles prévues
- ⑤ Plan de suivi (post-market / révision)

Logiciels d'aide : <https://www.cnil.fr/fr/outil-pia-telechargez-et-installez-le-logiciel-de-la-cnil>

Analyse d'Impact (AIPD / DPIA)

- Objectif : prouver que les risques ont été identifiés et réduits
- Contenu minimal : finalité, données, risques, mesures, durée
- Obligatoire si : profilage, surveillance, ou données sensibles à grande échelle

Mini-AIPD pour vos projets

- ① Finalité / description du traitement
- ② Données collectées / source
- ③ Risques identifiés
- ④ Mesures d'atténuation
- ⑤ Rétention / suppression

Cas récents et débat

Cas récents (2023–2025)

- Interdiction de la reconnaissance d'émotions sur le lieu de travail (Art. 5 AI Act)
- Registre public des IA à haut risque (EU AI Office)
- Amende CNIL à Criteo (40 M€) : absence de consentement valide
- Projet italien de credit scoring algorithmique retoqué
- Cookies illégaux, encore en 2025



Ce que dit la loi. L'AI Act classe comme **pratique interdite** (*art. 5*) les systèmes visant à *inférer les émotions* d'une personne dans des contextes sensibles (travail, éducation, etc.).

Pourquoi ? Risque d'atteinte à la dignité, d'erreurs systématiques et de manipulation comportementale.

Impact HAI. Les “scores d'émotions” pour évaluer un agent (call-center, entretien) **doivent être retirés** ou réaffectés à des usages techniques non évaluatifs.

Pour aller plus loin : EUR-Lex — Règlement (UE) 2024/1689 (AI Act) ; Parlement européen — Dossier “EU AI Act”.



Principe. Avant mise sur le marché, les systèmes *haut risque* doivent être **déclarés** et documentés (description, finalité, performances, supervision, logs).

Objectif. Créer une **traçabilité** et une **redevabilité** publiques (équivalent “model card” institutionnelle).

Impact HAI. Vos prototypes doivent déjà prévoir : *fiche technique + plan de suivi post-déploiement* (incidents, mises à jour, limites connues).

Pour aller plus loin : Commission — European AI Office (rôle et gouvernance) ; EUR-Lex — AI Act (art. 60 et s. sur base de données/registre).



Les faits. En 2023, Criteo (AdTech) a été sanctionné pour **absence de preuve de consentement** valable au ciblage publicitaire (chaîne de partenaires, cookies).

Base juridique. Violations liées à la **licéité** (art. 6) et la **preuve du consentement** (art. 7).

Impact HAI. *Pseudonyme* $\neq$ *hors RGPD*. Si le traitement repose sur le consentement, il doit être **obtenu et traçable** (logs, preuves d'opt-in).

Pour aller plus loin : EDPB — Note "Criteo fined €40M" ; Criteo — Communiqué (droit de réponse).



Les faits. Le *Redditometro* (profilage fiscal par indicateurs de dépenses) a été **suspendu** par le gouvernement italien en mai 2024 après contestations.

Enjeu. Transparence et proportionnalité du profilage, risques d'**erreurs** et de **discrimination** indirecte.

Impact HAI. Pour des systèmes d'aide à la décision **socio-fiscaux/financiers**, prévoir : *explicabilité actionnable, revue humaine, mécanismes de recours*.

Pour aller plus loin : RAI — Annonce publique de suspension (22/05/2024) ; Synthèse Décret 7 mai 2024 + *atto di indirizzo* (23/05/2024).



Les faits. En 2025, plusieurs autorités européennes (CNIL, AEPD, DPA irlandaise) ont infligé des **amendes record** à de grands acteurs du e-commerce et des médias numériques pour **non-respect du consentement aux traceurs**.

Exemples :

- CNIL : **50 M€** à Shein Europe pour absence d'opt-in clair sur les traceurs publicitaires.
- DPC (Irlande) : **25 M€** à Google pour *dark patterns* lors de la collecte du consentement sur YouTube.

Base juridique. Double : **RGPD (art. 6–7)** et **Directive ePrivacy (art. 5.3)**³.

Impact HAI. Le **design des interfaces de consentement** (bannières, options par défaut) relève aussi de l'**interaction humain-IA** : formulation, accessibilité, choix réels, logs de décision.

Pour aller plus loin : CNIL – Actualités (2025) ; EDPB – European Data Protection Board, News ; Directive 2002/58/CE – ePrivacy.

3. ≠ Règlement ePrivacy en cours d'adoption

Synthèse

À retenir

- ① $HAI \leftrightarrow HCAI = \text{design} + \text{preuve}$
- ② RGPD protège les personnes ; AI Act encadre les systèmes
- ③ L'AIPD devient une batterie de "*tests unitaires éthiques*"
- ④ Le designer HAI devient acteur-clé de la conformité

- Compléter (pour vous) la fiche **Conformité** dont le contenu sera à réutiliser :
 - base légale et durée de rétention
 - mesures de pseudonymisation
 - mini-AIPD intégrée